

PART I

1. Authority

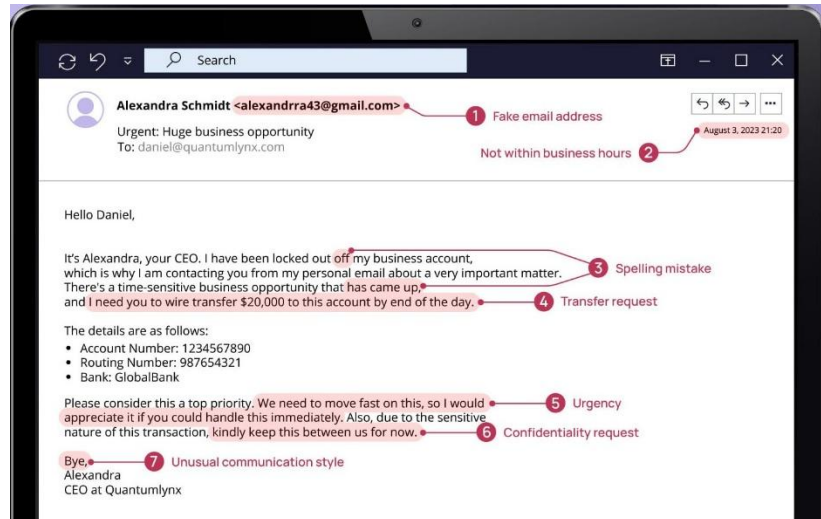
“Authority” refers to attackers assuming an authoritative or trusted position for example: an executive, an IT-administrator, or a policeman so that the target feels compelled to comply because of perceived hierarchy, expertise, or legitimacy. The psychological basis is an authority bias: people are more likely to follow instructions when they believe they come from someone in power.

Typical Execution:

- The attacker sends an email or makes a phone call purporting to be from a senior figure such as CEO, CFO, head of IT, asking the target to perform some action like transfer funds, reveal credentials, open a file.
- The attacker may dress up in official uniform, use executive titles, or spoof email domains to look like a trusted authority.
- By leveraging urgency “this must be done now” the authority angle becomes more compelling.

Real-World Scenario:

One study found that in phishing and spear-phishing experiments, emails that used an authority cue were significantly more successful in tricking people than those relying on social proof alone. Another broader example: the Cambridge Analytica case illustrates how manipulative techniques including authority cues were used at scale to influence behavior.



2. Baiting

In **baiting**, the attacker offers some “bait” physical or digital that appears appealing like a free USB drive, free software, music download, gift-card link with the objective that the victim will



engage and thereby trigger malware installation or give up credentials.

Typical Execution:

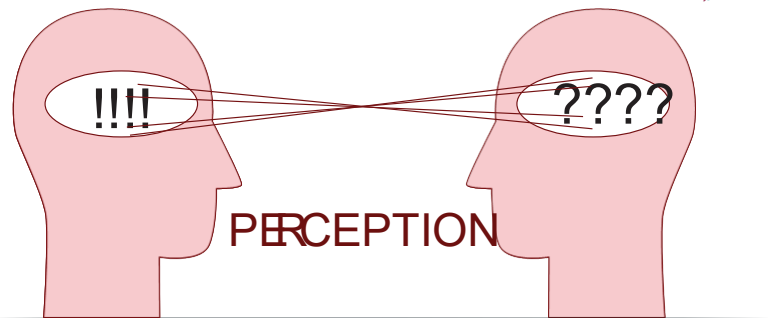
- A USB stick loaded with malware is left in a parking lot of a target organization.
- The victim picks up the drive, plugs it into their system, thereby infecting the network.
- Alternatively, an online “free download” link impersonates something desirable, clicks lead to malicious payloads.

Real-World Scenario:

In a 2016 experiment at the University of Illinois, researchers dropped 297 USB flash drives around campus; 98% of the drives were moved, 45% of those moved were plugged into machines.

3. Dual Reality

Dual reality is described as “a technique where two (or more) parties are experiencing the same thing but how they internalize the event is different.” In other words, the attacker creates a scenario that looks different to the victim(s) than it does to others or than the attacker intends. This is less commonly labelled but essentially involves manipulation of perception across different audiences.



Typical Execution:

- An attacker might stage a situation in which insiders think everything is normal, while the attacker is orchestrating control or covert access behind the scenes.
- For example, an attacker may synchronize a real event with a fake version of it for the victim to believe, while the attacker uses the “real” version to extract information or manipulate the environment.

4. Dumpster Diving



Dumpster diving is a social engineering / physical attack technique where the attacker goes through an organization or individuals' trash (documents, storage media, drives, etc.) to find sensitive information such as account numbers, internal memos, passwords, IDs, that can be used later for compromise.

Typical Execution:

- The attacker researches what kinds of documents a company throws away.
- They extract financial records, client lists, internal memos, shredded but recoverable documents, and use this to build malicious exploits (identity theft, spear-phishing, etc.).

Real-World Scenario:

In one case, two separate medical facilities in Hiram, Georgia left barrels of recycled paper and sensitive records such as social security numbers, addresses, in a dumpster, freely accessible.

5. Phishing

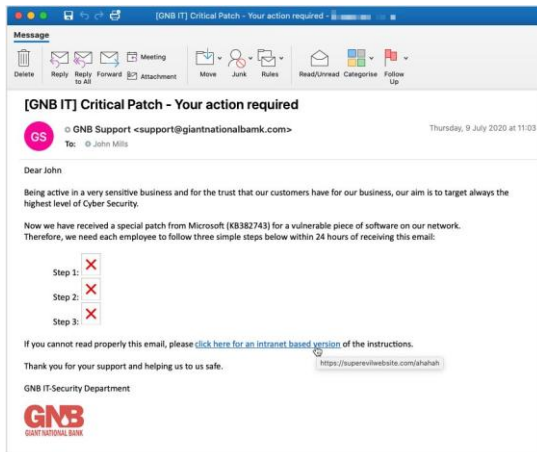
Phishing is the attempt to lure a victim into a trap (often via email, link, or website) that appears legitimate but is crafted to steal credentials, download malware, or extract sensitive information.

Typical Execution:

- A malicious email appears to come from a trusted source (bank, vendor, internal colleague) and asks the target to click a link or open an attachment.
- The link leads to a fake login page or triggers malware.

Real-World Scenario:

For example, a fraud campaign at Crelan Bank in Belgium lost €78 million because of a phishing email.



From: authenticationmail@trust.ameribank7.com
To: johnsmith@email.com
Subject: A new login to your bank account



Bank of America

Dear account holder,
There has been a recent login to your bank account from a new device:
IP address: 192.168.0.1
Location: Miami, Florida
4 new transactions have been made with this account since your last login.

If this was not you, please reset your password immediately with this link:
<https://trust.ameribank7.com/reset-password>

Thank you,
Bank America

6. Pretexting

Pretexting is where an attacker builds (or leverages) a plausible scenario (a “pretext”) to convince the target to divulge sensitive information or perform actions the victim would not otherwise do. The attacker typically impersonates someone trusted like IT support, co-worker, vendor, authority and uses that relationship to extract access or data.

Typical Execution:

- The attacker researches the target (job role, contacts, relationship network).
- They call or email the target, claim to be from IT or a partner, say “we are doing urgent maintenance” or “we noticed suspicious activity,” ask for credentials or request remote log-in.

Real-World Scenario:

The Hewlett-Packard (HP) spying scandal (2006) involved investigators impersonating board members and journalists to obtain phone records. Also, the Ubiquiti Networks (2015) fraud: executives impersonated, finance dept tricked into sending US\$46.7 million.



7. Quid Pro Quo

“Quid pro quo” in social engineering is “something for something” the attacker offers a service or benefit in return for access or information. The principle builds on reciprocity: humans tend to feel obliged to return a favor.

Typical Execution:

- Attacker calls staff pretending to be IT support, offers to “help” with a technical issue in exchange for the victim disabling security or admitting remote access.
- The victim, seeing the “help” as a benefit, may comply before realizing they’ve compromised themselves.

Real-World Scenario:

- A healthcare provider employee was contacted by someone claiming to be tech support, asked to disable antivirus and run a remote tool, this turned out to be malware installation.
- A much larger scheme (cited in a 2025 overview) described attackers that offered services (false recruitment, free Medicare calls) in exchange for access; also, one where internal staff of a crypto firm were bribed for access via quid pro quo.

8. Scareware

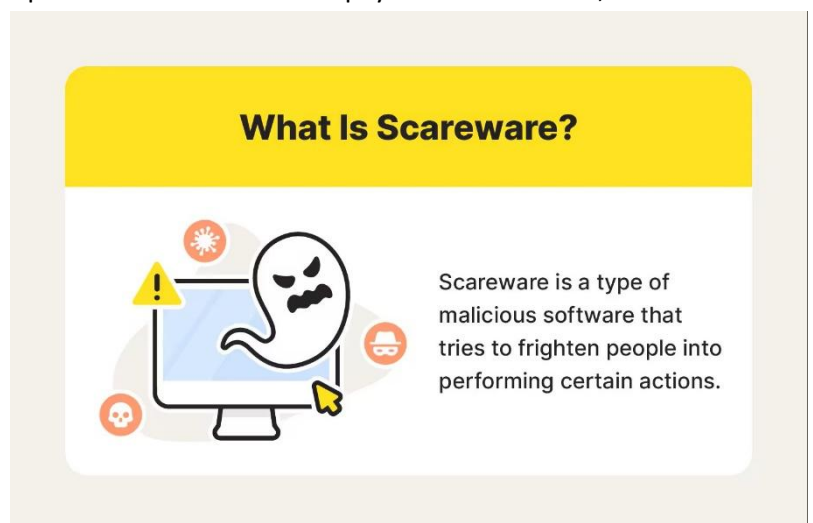
Scareware is a social engineering tactic where the victim is tricked into believing their system is infected or compromised, then prompted to take an action like pay for fake software, install malware. The fear of a threat is used to manipulate the victim into compliance.

Typical Execution:

- A popup appears: “Your computer has been infected click here to remove virus”.
- The victim clicks, either pays money or installs software that is malicious.

Real-World Scenario:

Operation Trident Tribunal (2011) targeted about a million users with fake antivirus/virus-



warning scareware, resulting in US\$72 million in victim payments.



9. Shoulder Surfing

Shoulder surfing is a physical / observational social engineering technique in which the attacker observes or records someone's screen, keypad entry, or other sensitive input (PIN, password, passcode) from behind or nearby.



Typical Execution:

- An attacker stands or sits behind a person in a café or tram, watches them type a PIN or password on a mobile device.
- With camera-enabled phones or hidden cams, the attacker may capture logins from a distance.

Real-World Scenario:

According to a diary-study on shoulder surfing: "The diary study showed that user's privacy is compromised in the naturalistic settings scenarios of shoulder surfing content-based shoulder surfing is more frequent than authentication-based shoulder surfing".

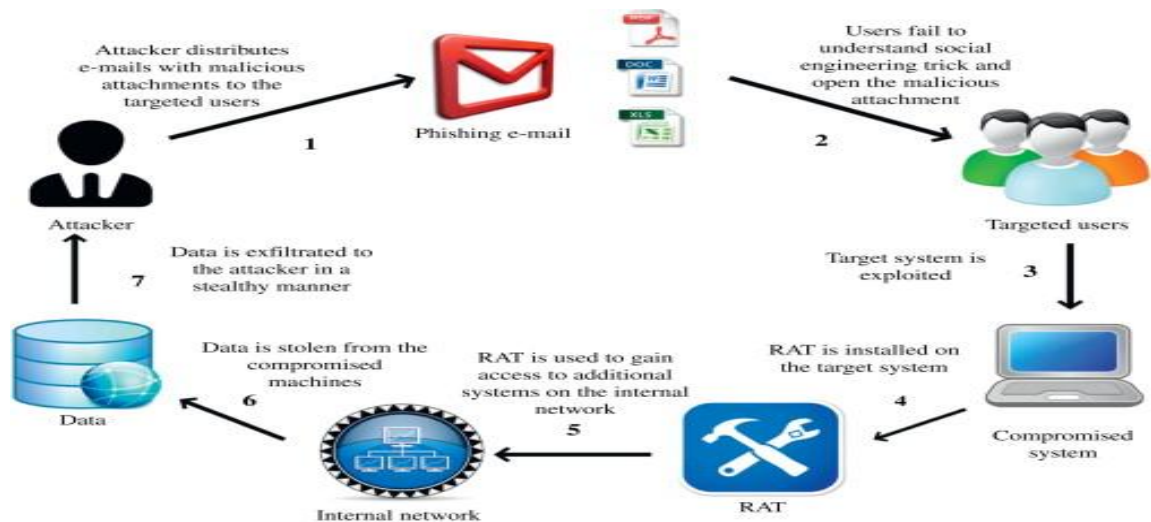
- The educational case of



“Kristýna, 21 years old” showed her logging into a system on a tram while a stranger had a clear view of her screen, a documented awareness-case of shoulder surfing.

10. Spear Phishing

Spear phishing is a highly targeted form of phishing where attackers tailor the message to a specific individual or organization, often using personal details or context to increase credibility. Sometimes a subset targeting high-profile personnel is called “whaling.”



Typical Execution:

- The attacker researches the target’s job role, contacts, recent events, names, and crafts an email that looks legitimate (“Here’s the invoice from our meeting last Tuesday, please sign and send payment”).
- The message may bypass generic filters because it’s personalized and speaks to the recipient’s context.

Real-World Scenario:

The Belgian bank Crelan fraud (2016) attackers impersonated senior executives and used contextual details to trick staff into large transfers.

11. Tailgating

Tailgating or piggybacking is when an unauthorized person gains access to a restricted area by following closely behind someone who is authorized, often exploiting politeness holding the door or impersonation.

Typical Execution:

- A person dresses as a delivery driver, maintenance worker, or similar, appears legitimate and follows someone through a door that required badge access.
- The authorized person holds the door open for them as act of a politeness.

Real-World Scenario:

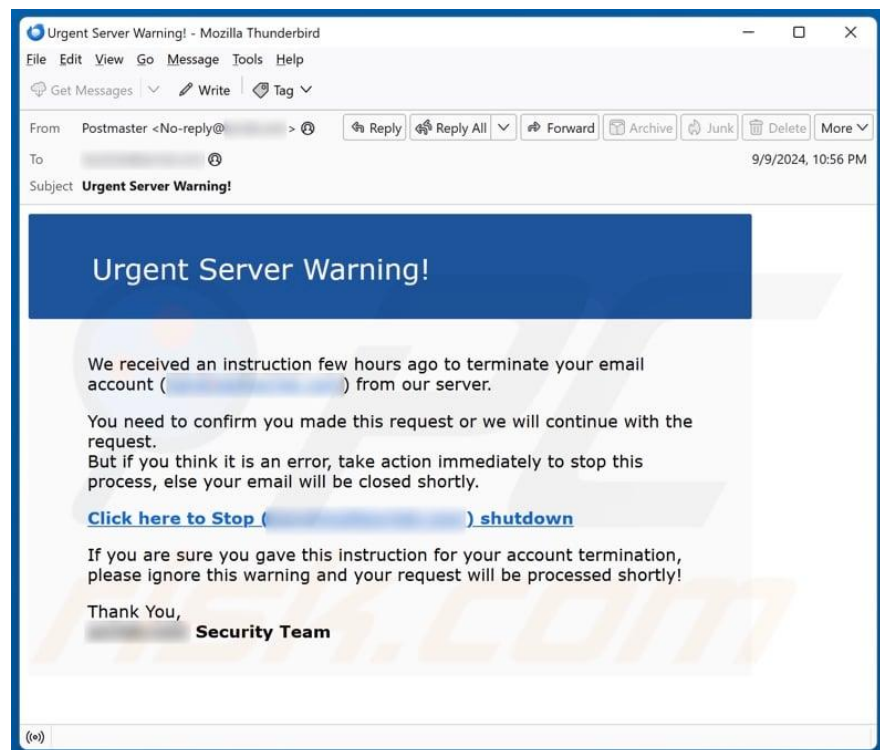
Listed in “9 Social Engineering Attack Examples to Watch Out For” by Lookout: tailgating described where attacker follows behind delivery or maintenance worker through secure door.

12. Urgency

“**Urgency**” is a psychological lever: attackers create pressure by imposing deadlines, stating account lockouts, limited offers, or emergencies, causing victims to act quickly without full verification. Though not always listed as a standalone technique, it’s a common element across many social engineering methods.

Typical Execution:

- An email says: “Your account will be suspended in the next 10 minutes unless you click this link and confirm your credentials.”
- Or a voicemail says: “We detected unauthorized access; you must call this number now.”



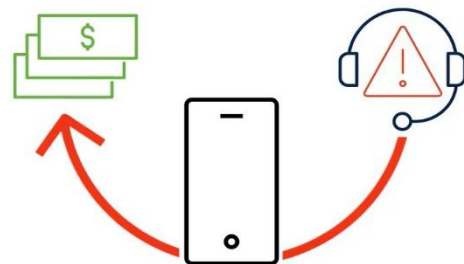
Real-World Scenario:

A business-email-compromise scenario described by Cyberly where attacker impersonated CFO/CEO and demanded urgent fund transfer "we need you to act now", leveraging urgency.

13. Vishing

Vishing (voice-phishing) is the use of voice calls or audio messages to deceive victims into giving sensitive information or authorizing actions (like transfers). Unlike email-phishing, it uses telephone or sometimes VoIP or voice-cloning.

Typical Execution:



- A fraudster calls posing as bank or IT support, perhaps spoofing the caller ID to appear legitimate.
- They might say: “We noticed unusual activity on your account. To protect you, I need you to confirm your credentials,” or “This transfer needs to be approved now.”

Real-World Scenario:

In 2020, the Twitter vishing attack: calls to employees impersonating internal staff led to credential compromise and hijacked high-profile accounts. Also, a Spanish “vishing” investigation March 2025 where nine people were investigated for bank fraud via phone calls.



14. Whaling

Whaling is a form of spear-phishing targeting high-profile individuals (CEOs, CFOs, board members). Because the target holds valuable privileges or access, the attacker can gain larger spoils. The email often looks like a legal notice, board directive, or urgent supervisory request.

Typical Execution:

- The attacker fabricates a request that appears to come from the CEO, board member, or business partner, instructing a subordinate (e.g., finance) to make a fund transfer, release documents, or share credentials.
- The victim’s trust in the high-ranking person causes them to comply quickly without normal verification.

Real-World Scenario:

The Belgian bank Crelan case (2016) where senior personnel were targeted, resulting in €70-75 million loss.

References

- Butavicius, M., Parsons, K., Pattinson, M., & McCormac, A. (2016). *Breaching the Human Firewall: Social Engineering in Phishing and Spear-Phishing Emails*. arXiv:1606.00887.
- Tischer, M., Benenson, Z., Friedberger, S., Lázaro, J., & Uellenbeck, S. (2016). *Users Really Do Plug in USB Drives They Find*. IEEE Symposium on Security and Privacy, 306–319.
- Boulton, C. (2016). *Whaling Emerges as Major Cybersecurity Threat*. CSO Online.
- Infosec Institute. (2016). *Mattel and FACC Hit by Whaling Attacks*. Retrieved from <https://resources.infosecinstitute.com>.
- UKDiss.com. (2024). *Social Engineering Overview: Techniques, Impacts and Defences*.
- Mitnick, K. D., & Simon, W. L. (2011). *The Art of Deception: Controlling the Human Element of Security*. Wiley Publishing.
- Symantec Corporation. (2019). *Internet Security Threat Report, Vol. 24*.
- Verizon. (2020). *Data Breach Investigations Report (DBIR)*. Verizon Enterprise.
- Krebs, B. (2016). *Dumpster Diving and Data Leaks*. Krebs on Security.
- Wired Magazine. (2013). *The Real-World Impact of Dumpster Diving Attacks*. Wired.com.
- Trend Micro. (2020). *Phishing and Social Engineering in the COVID-19 Era*. TrendMicro.com.
- BBC News. (2016). *Home Alone Burglars and Pretexting in Modern Scams*. BBC.com.
- Brushwood, B. (2018). *Scam School: The Psychology Behind Quid Pro Quo Attacks*. Modern Rogue Productions.
- Federal Bureau of Investigation (FBI). (2021). *Business Email Compromise (BEC) and Vishing Alerts*. FBI.gov.
- National Cyber Security Centre (NCSC). (2020). *Smishing and the Rise of SMS Fraud*. NCSC.gov.uk.
- Sophos. (2021). *Scareware: Fear as a Weapon in Cybercrime*. SophosLabs Technical Report.
- OSINT Foundation. (2022). *Spear Phishing and Reconnaissance Techniques in Targeted Attacks*.
- Cisco Talos Intelligence. (2021). *Tailgating and Physical Intrusion Risks*. Cisco.com.
- Proofpoint. (2023). *Vishing and Voice-Based Fraud Cases*. Proofpoint Threat Report.

